

DigitalBase セキュリティチェックシート

Security Checklist

最終更新日: 2026年5月

本チェックシートは、DigitalBase の導入にあたり、お客様の IT 部門・セキュリティ部門での審査にご利用いただくためのものです。

1. 製品概要

項目	回答
製品名	DigitalBase (旧名 LM Light)
提供元	デジタルベース株式会社
製品分類	オンプレミスソフトウェア
動作環境	お客様のサーバー / PC 上
配信形態	API + フロントエンドを単一プロセス・単一ポート (8000) で提供 (Node.js 不要、PyInstaller バイナリ / Docker Compose)
対応 OS	macOS / Linux / Windows

2. データ管理

No.	項目	回答
2.1	データの保存場所	お客様環境内のみ — PostgreSQL 17 + pgvector
2.2	クラウドへのデータ送信	既定は無し (完全オフライン動作可能。OpenAI / Anthropic / Gemini 等のクラウド LLM をオプションで利用する場合のみ、明示的な設定で外部 API に送信)
2.3		なし

No.	項目	回答
	テレメトリ / 利用統計の送信	
2.4	ライセンス認証の通信	なし — Hardware UUID ベースのオフライン認証
2.5	データの暗号化（保存時）	PostgreSQL の暗号化機能（TDE 等）に依存
2.6	データの暗号化（通信時）	Nginx リバースプロキシによる HTTPS 対応可能
2.7	データバックアップ	<code>pg_dump</code> による標準的な PostgreSQL バックアップ
2.8	データ消去	アンインストールスクリプトでアプリケーションデータ削除、 <code>DROP DATABASE</code> で完全消去
2.9	クラウド LLM 利用時の送信データ	プロンプト（質問文 + RAG コンテキスト）のみ。DB 全体やファイルは送信されない
2.10	Web 検索の送信データ	検索クエリのみ（DuckDuckGo / SearXNG）
2.11	第三者へのデータ提供	なし

3. 認証・アクセス制御

No.	項目	回答
3.1	認証方式	ローカル（ID/パスワード） / LDAP / OIDC から選択
3.2	LDAP / Active Directory 対応	対応 — AD / OpenLDAP（python-ldap3）。初回ログイン時にユーザー自動作成、LDAP 属性 30+ を <code>User.ldapAttributes</code> に保持
3.3	OIDC / Azure AD 対応	対応 — Microsoft Entra ID（python-jose）。初回サインイン時にユーザー自動作成
3.4	パスワードハッシュ	<code>passlib bcrypt</code> （12 ラウンド）
3.5	パスワードポリシー	LDAP/AD 利用時は AD 側ポリシーに準拠

No.	項目	回答
3.6	ロールベースアクセス制御	あり — ADMIN / SUPER / USER の 3 段階
3.7	セッション管理	JWT (HS256) + HTTP-only Cookie (有効期間 365 日、 <code>.env</code> で変更可)
3.8	管理者アカウントの保護	最後の ADMIN は削除・降格不可
3.9	デフォルトパスワード	初期: admin@local / admin123 — 初回ログイン後に変更必須
3.10	ユーザー数制限	ライセンスに基づく上限あり
3.11	AD/OIDC 環境の管理者アクセス	admin@local は常にローカル認証可能
3.12	共有ディレクトリ ACL / runAs	Bot・Pipeline に <code>shareType</code> (PRIVATE / TAG / PUBLIC) + <code>runAs</code> (caller / owner) + LDAP グループ → タグ自動マッピングを設定可能

4. ネットワーク

No.	項目	回答
4.1	必要なポート	DigitalBase (API + Web): 8000 , PostgreSQL: 5432, Ollama: 11434 (vLLM 版: 8080, 8081)
4.2	外部への通信	既定不要 。クラウド LLM / Web 検索 / MCP 有効化時のみ必要
4.3	HTTPS 対応	Nginx リバースプロキシにて対応可能
4.4	ファイアウォール設定	ufw による IP 制限・ポート制御をサポート
4.5	バインド設定	デフォルト <code>API_HOST=0.0.0.0</code> (LAN 内の他端末からアクセス可能)。 <code>127.0.0.1</code> に変更すると同一サーバー内のみに制限可
4.6	Webhook 送信先	Pipeline / 承認フロー / Helpdesk からの通知。送信先はユーザーが設定 (HMAC sha256 署名)
4.7	SMTP 送信	Pipeline からのメール通知。SMTP 設定は Pipeline ステップ内で指定

⚠ デフォルト設定では LAN 内の他端末からアクセスできます。同一サーバー内に閉じたい場合は `~/local/db/.env` の `API_HOST` を `127.0.0.1` に変更してください (vLLM 版は `~/local/db-vllm/.env`)。

5. アプリケーションセキュリティ

No.	項目	回答
5.1	SQL インジェクション対策	SQLAlchemy 2.0+ によるパラメータ化クエリ 。Pipeline SQL オペレータも <code>:param</code> 対応
5.2	XSS 対策	React の自動エスケープ処理
5.3	CSRF 対策	JWT 認証 + FastAPI CORS
5.4	API 認証	ライセンス検証 + セッション認証の二重チェック
5.5	ファイルアップロード制限	最大 100MB（音声ファイル）
5.6	API ドキュメント保護	本番ビルドでは Swagger UI / ReDoc は無効化または Basic 認証で保護
5.7	入力値バリデーション	FastAPI の Pydantic モデルによる型検証 + フロントエンド側バリデーション
5.8	コード実行サンドボックス	Pipeline のコード変換は危険なビルトイン（ <code>exec</code> , <code>eval</code> , <code>open</code> , <code>import</code> ）を除去、許可モジュールのみ利用可
5.9	Tool Calling のファイルアクセス	ホームディレクトリ内 or 指定ディレクトリのみ
5.10	Pipeline ループ保護	<code>max_iterations</code> 制限（既定 1000） + 指数バックオフリトライ

6. 監査・ログ

No.	項目	回答
6.1	チャット履歴	ADMIN が全ユーザーのチャット履歴を閲覧可能
6.2	アプリケーションログ	<code>~/.local/db/logs/</code> （vLLM 版は <code>~/.local/db-vllm/logs/</code> ）
6.3	Pipeline 実行履歴	実行日時、ステータス、ステップ結果、エラー詳細を DB 保存
6.4	最終ログイン記録	ユーザーごとに <code>lastLoginAt</code> を記録
6.5	外部 SIEM 連携	ログファイルを SIEM で取り込み可能（標準テキスト形式）

7. ソフトウェア構成

No.	項目	回答
7.1	フロントエンド	Vite + React 19 ビルド成果物（FastAPI が静的配信） + Zustand + localStorage
7.2	バックエンド	FastAPI (Python) + uvicorn
7.3	データベース	PostgreSQL 17 + pgvector（DB 名・ユーザー・パスワード: digitalbase）
7.4	ORM	SQLAlchemy 2.0+
7.5	LLM エンジン	Ollama（標準） / vLLM（高性能、RTX 50 Blackwell 対応 CUDA ビルドあり） / クラウド LLM（任意）
7.6	認証ライブラリ	python-jose (JWT) / python-ldap3 (LDAP) / passlib bcrypt
7.7	LLM 通信方式	httpx による OpenAI 互換エンドポイントへの直接 HTTP リクエスト（OpenAI SDK 不使用）
7.8	Pipeline	80+ オペレータ + APScheduler + ReactFlow
7.9	バイナリ配布	PyInstaller + Cython
7.10	OSS ライセンス	使用 OSS は各ライセンス条件に準拠（MIT, Apache 2.0, BSD 等）

Vite Edition への移行に伴い、Next.js 時代の `next-auth` / `bcryptjs` / `ldaps` 等の Node.js 系認証ライブラリは廃止されています。

8. ライフサイクル管理

No.	項目	回答
8.1	アップデート方法	インストールコマンドの再実行（データ保持）
8.2	セキュリティパッチ	脆弱性発見時に随時提供、ライセンス登録メール宛に緊急通知
8.3	EOL（サポート終了）通知	エンドユーザー: 3 ヶ月前 / パートナー: 12 ヶ月前
8.4	データ移行	pg_dump / pg_restore による標準手順
8.5	依存ソフトウェアの EOL 対応	Python / PostgreSQL 等の LTS 版を使用

9. コンプライアンス

No.	項目	回答
9.1	個人情報保護法対応	プライバシーポリシーにて取扱いを明記。お客様環境内にデータが留まるため当社がデータ処理者となることはない
9.2	データ所在地	お客様環境内（国内設置であれば国内）。クラウド LLM 利用時はプロバイダーの規約に準拠
9.3	第三者へのデータ提供	なし
9.4	ISMS（ISO 27001）	未取得（取得検討中）
9.5	プライバシーマーク	未取得
9.6	SECURITY ACTION	宣誓済み（一つ星）
9.7	GDPR	お客様環境内にデータが留まるため、当社側での GDPR 対応義務は発生しない
9.8	第三者監査	未実施（個別協議にて対応可能）

お問い合わせ

セキュリティに関する詳細な質問は、個別にお問い合わせください。

デジタルベース株式会社 - メール: info@digital-base.co.jp - ウェブサイト: <https://digital-base.co.jp> - プロダクトサイト: <https://digital-base.co.jp/lmlight>

Copyright (c) 2026 デジタルベース株式会社 All rights reserved.